

VIGIL

Toward Workflow-Aware Security and Runtime Trust-Transition Interpretation

Architecture Positioning Paper

Version 1.2
June 2026

Author

Maarten Albregts

Independent Security Architect
Sentyra

VIGIL Research

Exploring workflow-aware security, workflow continuity,
runtime trust transitions, and contextual reassessment
within modern identity-centric digital ecosystems.

github.com/malb8/VIGIL-research

Copyright © 2026 Sentyra. Licensed under the Apache License 2.0

Abstract

Modern phishing increasingly exploits trusted SaaS platforms, collaboration environments, delegated authorization workflows, and browser-mediated interactions rather than obviously malicious infrastructure. At the same time, enterprise security has become deeply identity-centric: identity fabrics, federated authentication, and interconnected SaaS ecosystems let users move seamlessly across applications and trust domains while experiencing these interactions as one continuous workflow.

VIGIL is an exploratory research initiative investigating the resulting **workflow security gap**: the separation between technical trust validation and how users interpret trust, workflow ownership, and interaction context as a workflow progresses. The central hypothesis is that some modern attacks derive their effectiveness from this distinction, allowing trust established in one context to influence security-relevant decisions made in another.

The initiative currently consists of two complementary research components — **VIGIL Email** (communication-layer context and trust establishment) and **VIGIL Gate** (browser-mediated workflows and runtime trust transitions). VIGIL is an architectural research initiative, not a production security platform, and does not propose deterministic phishing detection. It explores how workflow-aware security models may complement existing phishing-defense, identity-governance, and zero-trust architectures.

1. Introduction

Over the past decade, the enterprise security perimeter didn't just dissolve — it shattered. A typical business process now routinely hops between Microsoft 365, Salesforce, ServiceNow, Slack, and external identity providers before a task is completed. Users do not experience these transitions as separate events; to them, it is one continuous, frictionless workflow.

This transformation was enabled by cloud adoption, federated identity, single sign-on, delegated authorization, and identity-fabric architectures. These technologies perform their intended role effectively: authentication systems establish identity, authorization frameworks govern access, identity fabrics coordinate trust across platforms, and security controls continuously evaluate policy, risk, and session legitimacy.

From a technical perspective, trust decisions are constantly being evaluated and enforced. From a user perspective, most of these transitions are invisible. Users interact with applications, documents, collaboration requests, and authorization prompts as part of a broader workflow without considering where one trust boundary ends and another begins.

This paper argues that the divergence between these two perspectives — technical trust validation and human trust interpretation — has itself become part of the attack surface, and introduces VIGIL, a research initiative exploring whether workflow-aware security concepts can help close that gap.

2. The Evolution of Phishing

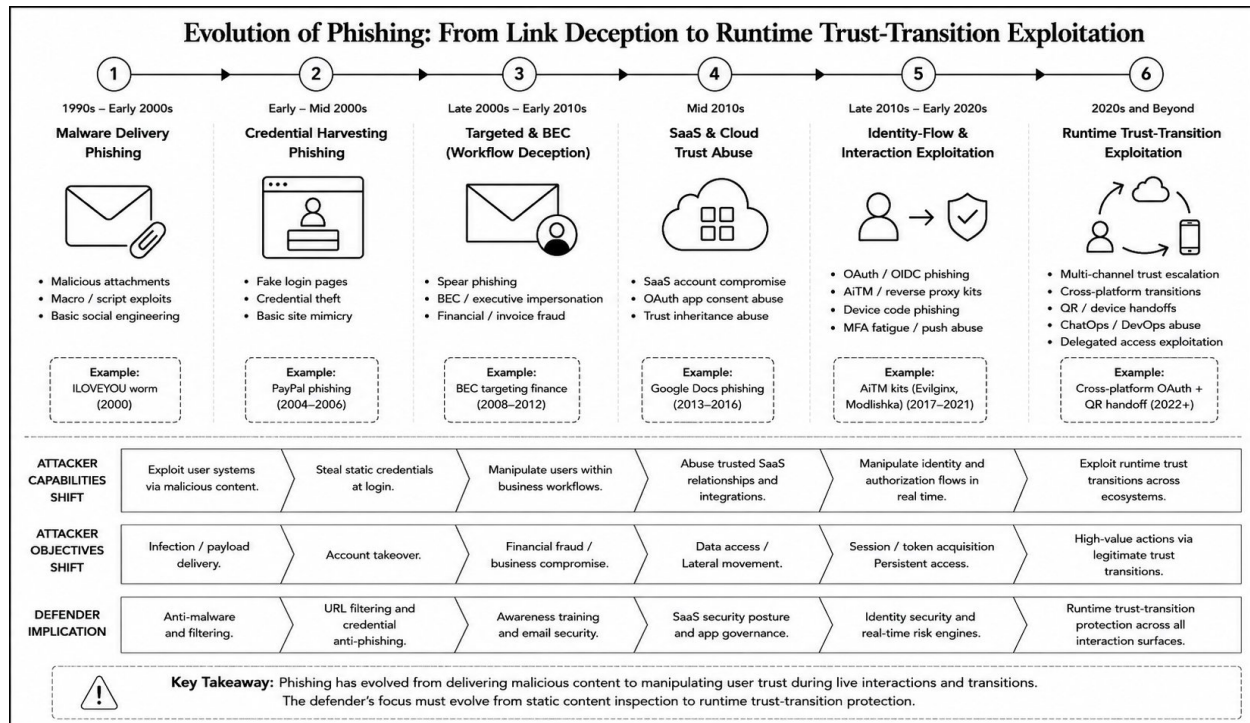


Figure 1 - Evolution of phishing: from malicious infrastructure to trusted platforms

For many years, phishing was relatively straightforward to describe. Attackers created fraudulent websites, spoofed trusted organizations, distributed malicious attachments, and stole credentials through deception. Success often depended on convincing users to interact with infrastructure that was visibly different from the systems they normally used.

Security technologies evolved accordingly. Email filtering, reputation services, browser protections, authentication technologies, attachment analysis, and endpoint security became highly effective at identifying malicious infrastructure and suspicious content. These controls continue to prevent a significant amount of phishing activity and remain a critical part of enterprise security.

The environment in which users work, however, changed considerably — and attackers adapted. Rather than building obviously malicious infrastructure, they now weaponize the enterprise's own platforms. By exploiting OAuth consent workflows, intercepting sessions via Adversary-in-the-Middle (AiTM) proxies, or abusing native cloud document sharing, the attack embeds itself directly into trusted corporate communication lines. The infrastructure is genuine, the certificates are valid — but the intent is malicious (Microsoft Threat Intelligence, 2023; MITRE ATT&CK, 2025; ENISA, 2024).

As a result, phishing can no longer be understood solely as a problem of malicious websites, fraudulent domains, or deceptive emails. A user may begin within a legitimate environment,

follow a familiar workflow, encounter a new authorization request or destination, and continue interacting without reassessing whether the new action still belongs to the original context.

This shift does not reduce the importance of traditional phishing defenses; it expands the problem space. Understanding how trust is established, maintained, and transferred across modern workflows has become essential to understanding how contemporary attacks succeed.

3. The Workflow Security Gap

3.1 Identity-Centric Architecture and Workflow Continuity

One of the most significant changes in modern enterprise architecture has been the shift from application-centric toward identity-centric security. Rather than establishing trust independently within each application, organizations rely on centralized identity services — identity fabric, federation, single sign-on, delegated authorization — to provide authentication, authorization, governance, and access control across large numbers of interconnected systems.

The business benefits are substantial: seamless access for users, reduced authentication friction, and centralized visibility and control for security teams. The resulting workflow continuity is not a weakness of identity-centric architectures — it is one of their primary objectives.

The consequence is a working environment in which a single task routinely spans multiple applications, organizations, services, and trust domains. A user may receive a collaboration request through email, access a document hosted in a SaaS platform, authenticate through an external identity provider, approve an authorization request, and interact with a third-party service — without perceiving any of these as separate security events.

3.2 Defining the Gap

Modern security architectures answer important questions:

- Is the user authenticated?
- Is access permitted?
- Is the application trusted?
- Does the request comply with policy?

What they do not explain is how trust is *interpreted* by users moving through workflows that span multiple systems and trust domains. A user rarely evaluates every action as an isolated event. Trust established earlier in a workflow shapes how later interactions are perceived: collaboration requests, shared documents, redirects, and authorization prompts all appear as natural continuations of the same task, even when they involve different systems, identities, permissions, or organizational boundaries.

Consequently, technical trust validation and human trust interpretation do not operate at the same level. A workflow may be technically legitimate while still creating uncertainty about context, ownership, or intent — and a sequence of individually legitimate actions may collectively produce a misleading impression of continuity that influences security decisions.

VIGIL calls this distinction the **workflow security gap**: the space between validating whether individual components of a workflow are technically trustworthy and understanding how trust is interpreted across the workflow as a whole.

The existence of this gap does not imply a failure of identity systems, authorization frameworks, or zero-trust architectures; these perform exactly the functions they were designed to perform. The gap highlights an area that has simply received less attention: how trust evolves, propagates, and is interpreted as users navigate interconnected digital environments.

3.3 Research Premise

VIGIL does not assume that modern identity, delegated-authorization, or federation technologies are fundamentally flawed. It investigates two related questions:

1. Do users routinely make trust decisions based on *perceived workflow continuity* rather than on the specific security-relevant action currently being requested?
2. Do some modern attacks derive their effectiveness precisely by exploiting this distinction?

4. Trust Transitions in Browser-Mediated Workflows

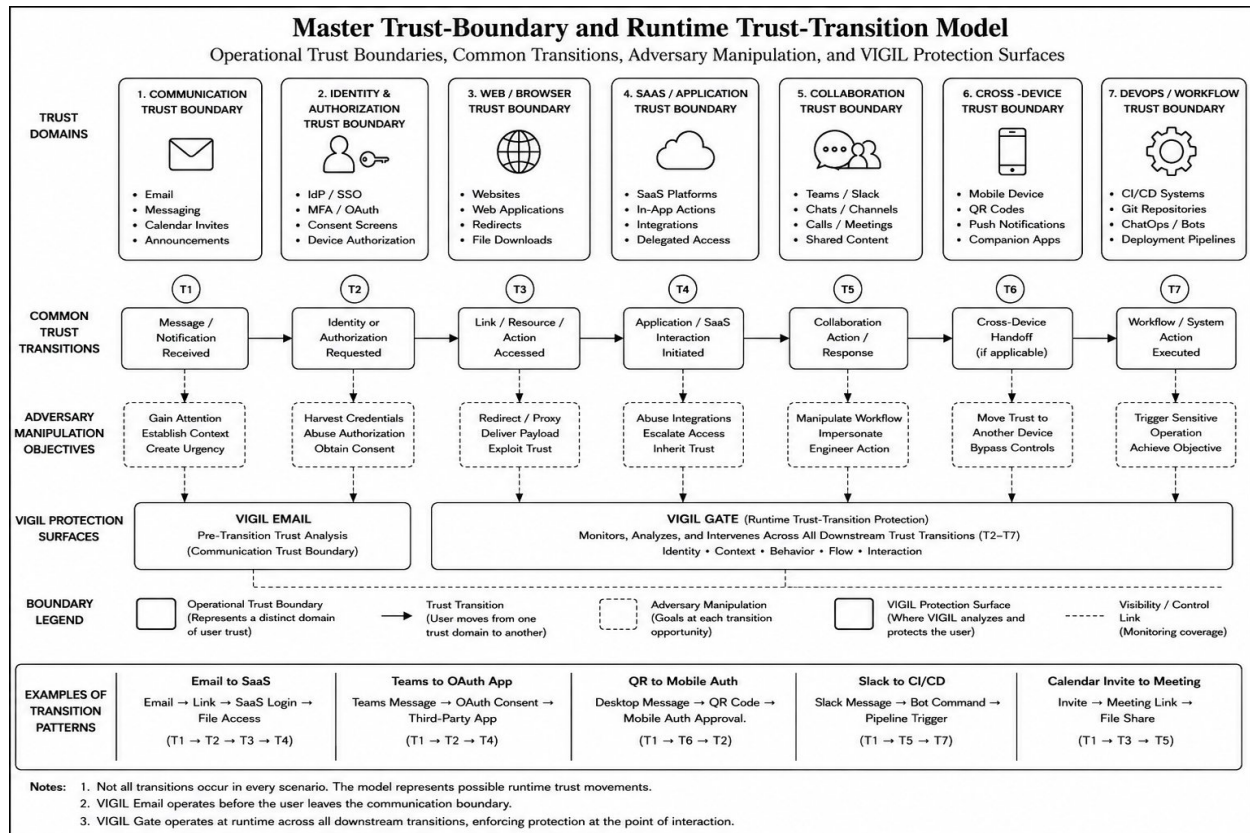


Figure 2 - Master trust boundary diagram: trust domains and workflow transitions

From a technical perspective, each hop in a cross-application workflow is a movement between distinct trust relationships: different applications, organizations, identity providers, authorization scopes, and policy frameworks become involved as the workflow progresses. These transitions are routinely evaluated by security controls — but they are rarely visible to the user.

VIGIL refers to these moments as trust transitions: points at which trust established in one context influences decisions made in another. A collaboration request may increase confidence in a document-sharing workflow; a trusted application may color how an authorization request is perceived; a familiar workflow may reduce scrutiny when a new destination appears. Trust transitions are not inherently malicious — they are a natural consequence of how modern ecosystems operate — but they are the points where assumptions about trust, ownership, legitimacy, and continuity can change.

Figure 2 illustrates this as a series of trust boundaries connected by workflow progression. Rather than treating interactions as isolated events, the model considers how trust may be established, reinforced, inherited, challenged, or reassessed as users move between environments at runtime. Its purpose is not to judge whether a particular action is legitimate, but to provide a

framework for understanding where ambiguity emerges as users cross application, organizational, and authorization boundaries.

4.1 A Taxonomy of Deceptive Trust Transitions

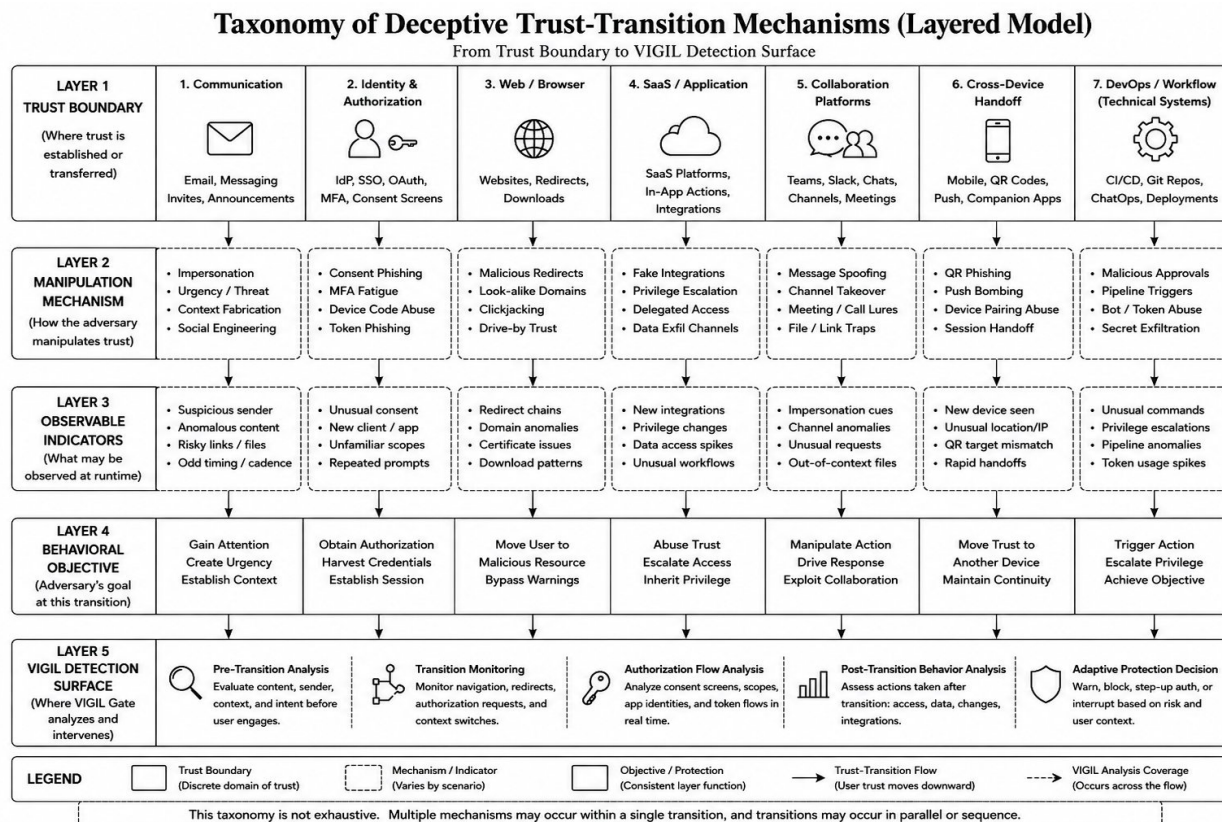


Figure 3 - Taxonomy of Deceptive Trust Transitions: establishment, manipulation, transition, and user impact

To reason about these interactions systematically, VIGIL organizes deceptive trust into four areas:

1. **Trust establishment.** Workflows derive initial credibility from trusted communication channels, identity systems, collaboration platforms, SaaS applications, and established business processes.
2. **Trust manipulation.** Attackers exploit familiarity, workflow expectations, delegated authorization processes, or trusted platforms to influence how subsequent interactions are interpreted.
3. **Trust transitions.** As users move between applications, services, documents, identity providers, and authorization contexts, trust is inherited from earlier stages even when the surrounding context changes.
4. **User impact.** Inherited trust influences security-relevant decisions: authorization approval, credential submission, document access, workflow compliance.

The taxonomy is not a catalog of attack techniques and does not attempt to classify every phishing variant. It provides a conceptual vocabulary for discussing how trust behaves in workflow-driven environments, complementing traditional views that focus on individual artifacts — emails, domains, attachments, websites. It serves as the conceptual foundation for the VIGIL architecture.

5. The VIGIL Architecture

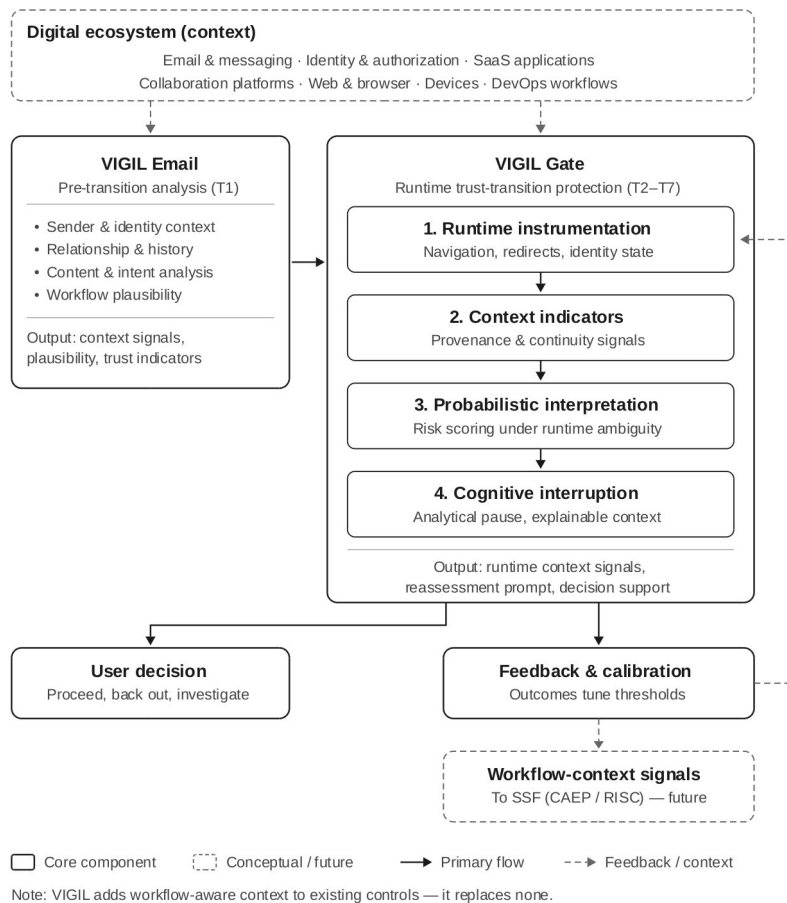


Figure 4 - VIGIL architecture: VIGIL Email pre-transition analysis (T1) and the VIGIL Gate runtime pipeline (T2–T7) with feedback calibration and future signal output

VIGIL explores how workflow-aware security concepts can be applied across the stages of a digital interaction, rather than at a single channel or artifact. The initiative currently consists of two complementary components that address different stages of the same problem.

VIGIL Email focuses on the communication layer, where trust is *established*. The objective is not to analyze individual messages in isolation, but to examine how communication fits within broader workflows, expected interactions, and organizational context. The component explores

workflow plausibility, communication continuity, and contextual indicators that influence trust during message-driven interactions — before a workflow progresses into subsequent stages.

VIGIL Gate focuses on browser-mediated workflows, where trust *evolves*. It investigates how users navigate between applications, services, documents, identity providers, and authorization contexts after an interaction has begun, with particular attention to navigation context, workflow continuity, trust transitions, and moments where previously established trust assumptions deserve renewed evaluation. A functional browser prototype has been developed to study these dynamics during real-world browsing activity.

Prototype development made the abstraction concrete. Under real-world browser conditions, navigation provenance proved more ambiguous than expected: a browser tab opened deliberately by a user can be visually identical to one produced through an inherited redirect chain originating from an external collaboration workflow — yet the two represent materially different trust conditions. Browser lifecycle states, startup-restored sessions, single-page-application transitions, and externally initiated browser launches all produce interaction patterns in which the same visible destination carries different security meaning depending on how the user arrived there. This observation — that identical destinations can have different provenance, and that provenance is largely invisible to both the user and artifact-centric controls — is the empirical core of the Gate research.

VIGIL Gate therefore evaluates runtime context indicators rather than destinations alone. Indicator categories that emerged during prototype development include:

- redirect-inheritance continuity across browser-mediated navigation flows;
- externally initiated browser launches originating from collaboration platforms or OS-level interaction surfaces;
- browser lifecycle restoration states, such as startup-restored sessions and previously suspended workflow contexts;
- navigation-provenance consistency between observed transitions and expected user interaction patterns;
- interaction-timing irregularities during rapid redirect or delegated authorization sequences;
- unexpected trust-boundary transitions between operationally distinct platforms or identity contexts;
- divergence between explicitly user-initiated navigation and browser-mediated workflow continuation.

These indicators are contextual inputs to probabilistic interpretation, not detection heuristics: similar patterns arise in entirely legitimate workflows through ordinary SaaS behavior, federated identity transitions, and browser-managed session continuity. A typical transition pattern illustrates the scope: a Teams message leads to an OAuth consent screen for a third-party

application, crossing the communication, identity, and application trust boundaries (T1 → T2 → T4) — three legitimate artifacts, one inherited trust assumption, and a final action whose security significance depends entirely on the workflow that produced it.

VIGIL does not attempt to replace existing phishing defenses, secure email gateways, browser protections, identity systems, or zero-trust architectures. It explores whether workflow-aware concepts can provide an *additional layer of context* for interactions that span multiple systems, trust domains, and authorization boundaries — supporting contextual reassessment at moments where workflow continuity, trust inheritance, or runtime ambiguity may influence security decisions, rather than rendering authoritative judgments about legitimacy or malicious intent.

6. Contextual Reassessment

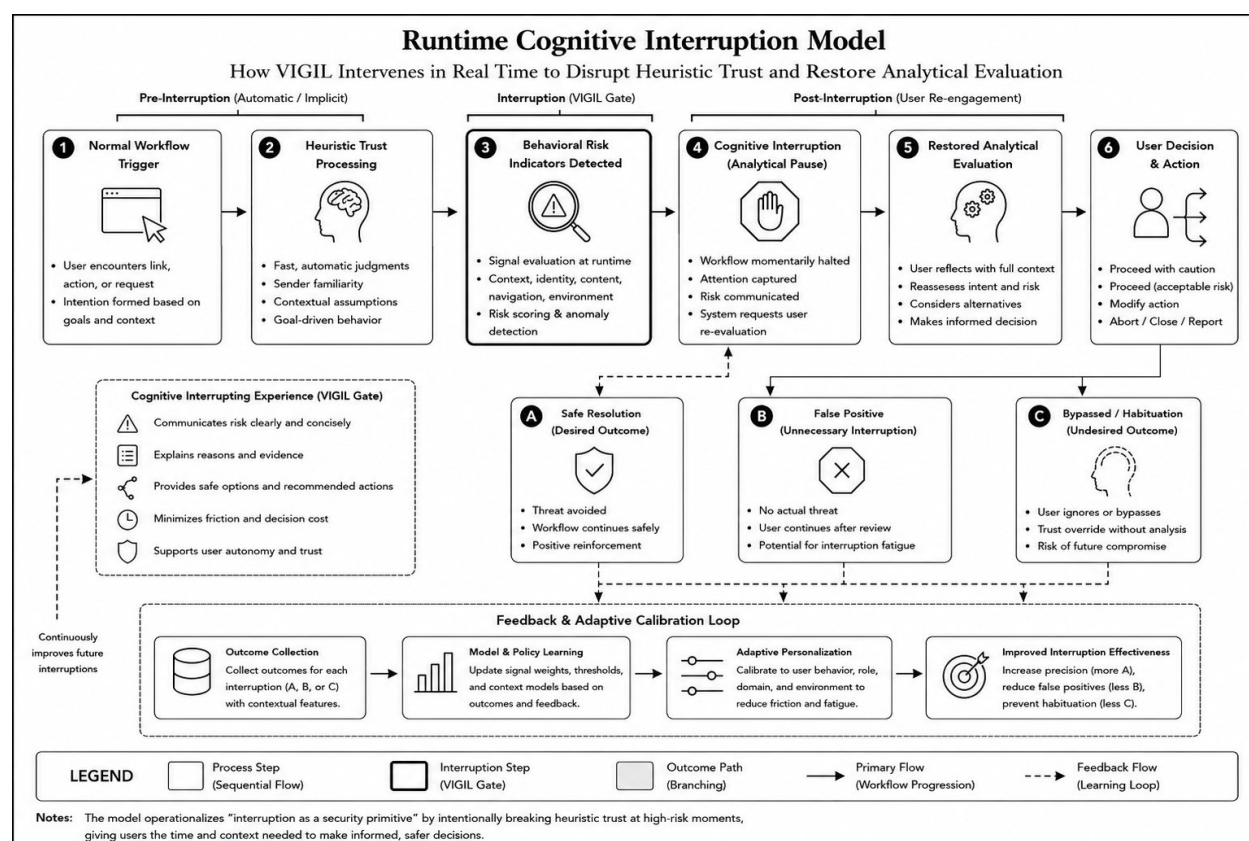


Figure 5 - Runtime cognitive interruption model: breaking heuristic trust at high-risk transitions to restore analytical evaluation

Modern security controls are designed to allow, block, or challenge. Many of today's attacks, however, operate where the underlying services are legitimate, authentication functions correctly, and no obvious indicators of compromise are present.

Consider a user who receives a document request in Teams, opens a SharePoint document, authenticates through Microsoft 365, and is then presented with an OAuth consent screen for a third-party application. Each step appears reasonable in isolation. The question is whether the final action still belongs to the workflow the user believes they are participating in.

This is where the human trust model breaks down. We have spent years training users to look for broken padlock icons and misspelled domains — but that training does not prepare them for a perfectly legitimate redirect to a verified-but-compromised Azure tenant requesting application permissions. VIGIL targets these exact inflection points: not by guessing whether an artifact is malicious, but by prompting a cognitive pause when the trust context fundamentally changes.

The Runtime Cognitive Interruption Model (Figure 5) proposes that users occasionally benefit from being reminded that a meaningful trust decision is taking place. The goal is not to interrupt normal work, but to draw attention to moments where context, ownership, authorization scope, destination, or workflow progression has changed — for example: unexpected authorization requests, externally initiated browser activity, unusual redirect chains, delegated access approvals, or navigation paths that depart from normal user expectations.

In dual-process terms (Kahneman, 2011), workflow continuity is precisely what keeps users operating in fast, automatic System 1 mode — and trust transitions are precisely the moments where System 1 is unsafe. The interruption is a intentional, low-cost switch to deliberate System 2 reasoning, applied only at the points where the trust context has materially changed.

The underlying principle is simple: **trust established at the beginning of a workflow should not automatically apply to everything that follows**. VIGIL therefore explores whether timely contextual guidance can help users recognize important transitions and make more deliberate decisions — understanding where they are, how they arrived there, and whether the current interaction still aligns with the workflow they intended to follow.

7. Related Work and Positioning

The problems explored in this paper intersect several established domains — phishing detection, usable security, browser security, identity architecture, and trust modeling — and VIGIL claims no novel phishing phenomena within any of them. The contribution is architectural and interpretive: a framework that combines workflow-continuity analysis, trust-boundary reasoning, and runtime provenance interpretation into a single model of how trust is inherited across browser-mediated workflows.

Phishing detection research has historically been infrastructure-centric: malicious-domain identification, sender authentication, URL and attachment analysis, and machine-learning classification (Dhamija et al., 2006; Khonji et al., 2013). These approaches remain effective and

necessary. However, operational research increasingly documents campaigns built on legitimate services, trusted cloud infrastructure, and delegated identity systems (Microsoft Threat Intelligence, 2023; Mandiant, 2023; Proofpoint, 2024; FBI IC3, 2024) — attacks that artifact-centric controls are structurally poorly positioned to evaluate, because no artifact is malicious. VIGIL addresses the layer those controls do not: the transition between legitimate artifacts.

Usable-security research has established that security behavior cannot be separated from interface design, cognitive load, and workflow expectations (Cranor, 2008; Beautelement et al., 2009), and that browser warnings habituate badly — users learn to dismiss high-frequency, blocking, predominantly false-positive prompts (Sunshine et al., 2009; Akhawe & Felt, 2013; Bravo-Lillo et al., 2013; Felt et al., 2015). VIGIL accepts these findings rather than arguing against them, and they directly shape the Runtime Cognitive Interruption Model. The interruptions studied in the warning literature were frequent, verdict-rendering ("this site may be dangerous"), and usually wrong. VIGIL's interruptions are deliberately the opposite on each dimension: rare (triggered only by material trust-context changes such as externally initiated navigation or cross-tenant authorization requests), informational rather than verdict-rendering ("your trust context has changed"), and anchored to events that are factually true by construction. Whether this profile resists habituation in practice is an open empirical question (§8), but it is a different design point from the warnings that the fatigue literature examined.

Enterprise browsers and browser-security controls increasingly govern what users can do within managed browsing sessions, and overlap with VIGIL Gate's observation layer. VIGIL differs in intent and scope: enterprise browsers enforce policy within a vendor-controlled boundary, whereas VIGIL models trust transitions across boundaries — including ones no single vendor controls — and is conceived as vendor-neutral. The concepts described here could be implemented inside an enterprise browser; they are not equivalent to one.

Continuous and signal-based identity evaluation. The OpenID Shared Signals Framework (SSF), with its CAEP and RISC event profiles — of which Microsoft's Continuous Access Evaluation (CAE) is a vendor implementation — re-evaluates sessions when technical risk signals change. These frameworks consume signals; they do not generate workflow-context signals. VIGIL is positioned as complementary: workflow provenance and trust-transition events are a candidate signal class that such frameworks currently lack, and feeding them is an explicit research direction (§8) rather than a competing mechanism.

In summary: the individual phenomena — OAuth abuse, AitM proxying, redirect chains, collaboration-platform impersonation, warning habituation — are well established. What existing work does not provide is a unified runtime model of how trust is established, inherited, and misinterpreted *across* these mechanisms during a single perceived workflow. That model is the contribution this paper proposes.

8. Research Direction and Open Questions

VIGIL remains an active research initiative focused on architectural exploration rather than large-scale deployment. Active topics include workflow provenance, delegated authorization analysis, browser-mediated trust transitions, contextual explanation models, user decision-making during workflow progression, and the effectiveness of contextual reassessment as a security intervention.

Translating the conceptual research into practical enterprise architecture raises several open questions for the community:

1. **Telemetry vs. interruption fatigue.** How can VIGIL balance runtime cognitive interruptions without recreating the alert fatigue of legacy browser warnings? Should VIGIL evolve from an interruption model into a pure contextual-telemetry provider for downstream IAM systems?
2. **Cross-domain state management.** What architecture — enterprise browser extensions, managed browsers, or OS-level hooks — is required to maintain workflow provenance and lineage as a user moves across distinct applications and protocols?
3. **Integration with emerging IAM standards.** How can the VIGIL framework feed open identity standards — the OpenID Shared Signals Framework (SSF) and its CAEP/RISC event profiles — so that workflow-context observations become actionable for existing identity infrastructure?

8.1 Architecture Vision: A Workflow-Context Signal Layer

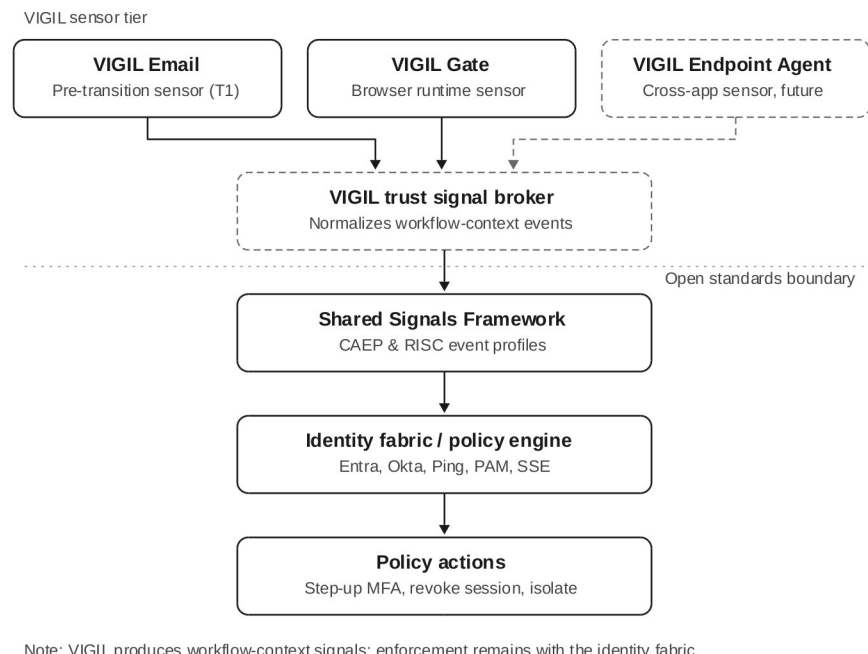


Figure 6. VIGIL workflow-context signal layer — sensors, broker, and standards boundary

The questions above converge on a longer-term architecture vision in which VIGIL evolves from a set of standalone components into a workflow-context signal layer for identity-centric security. The model has three sensor tiers feeding a common pipeline:

1. **VIGIL Email** — the pre-transition sensor at the communication trust boundary (T1), as described in §5.
2. **VIGIL Gate** — the browser runtime sensor observing trust transitions during navigation, redirects, and authorization flows.
3. **VIGIL Endpoint Agent** (*future, conceptual*) — a cross-application sensor for transitions that never traverse the browser. Gate's observation boundary is the browser: links that launch native applications through protocol handlers (`ms-word:`, `msteams:`), interactions rendered inside embedded webviews, and document-to-application handoffs are invisible to a browser extension, even though the same trust-inheritance dynamics apply. An endpoint tier would extend the model across those boundaries; it is deliberately scoped here as an architectural concept rather than an implementation commitment.

Sensor observations would flow through a trust signal broker (*future, conceptual*) that normalizes browser, email, and endpoint observations into identity-consumable risk events, emitted through the Shared Signals Framework (CAEP/RISC) to the organization's existing identity fabric — Entra, Okta, Ping, PAM, or SSE platforms — which decides on policy actions such as step-up authentication, session revocation, or isolation.

Two properties of this model are deliberate. First, the standards boundary: everything VIGIL-specific sits above the SSF interface, so the identity ecosystem consumes workflow-context events without adopting VIGIL-proprietary integration. Second, the non-enforcement principle: VIGIL produces signals describing what identity systems cannot currently see — how a user arrived at a security-relevant action — while enforcement authority remains entirely with the identity fabric. This division answers the practical objection that workflow-aware security requires yet another enforcement agent: it does not. It requires a new signal class, and the consumption infrastructure for that class already exists.

9. Conclusion

Identity-centric architectures, SaaS ecosystems, delegated authorization, and browser-mediated workflows have made digital work seamless across applications, organizations, and trust domains — and attackers have adapted, deriving credibility from trusted platforms and expected business processes rather than from malicious infrastructure.

The central premise of this paper is that technical trust validation and human trust interpretation are not the same thing, and that the space between them — the workflow security gap — deserves explicit architectural attention. VIGIL explores that space through workflow continuity,

trust transitions, deceptive trust propagation, and contextual reassessment, investigating how workflow-aware models may complement existing controls by providing visibility into how trust evolves at runtime.

The ideas presented here are an architectural and research perspective, not a finished security solution. As digital ecosystems grow more interconnected, understanding how trust moves through workflows may become an important area of security research. VIGIL represents one exploration of that challenge.

References

- Akhawe, D., & Felt, A. P. (2013). *Alice in Warningland: A large-scale field study of browser security warning effectiveness*. USENIX Security.
- Beautelement, A., Sasse, M. A., & Wonham, M. (2009). *The compliance budget: Managing security behaviour in organisations*. NSPW.
- Bravo-Lillo, C., et al. (2013). *Your attention please: Designing security-decision UIs to make genuine risks harder to ignore*. SOUPS.
- Cranor, L. F. (2008). *A framework for reasoning about the human in the loop*. UPSEC.
- Dhamija, R., Tygar, J. D., & Hearst, M. (2006). *Why phishing works*. CHI.
- ENISA (2024). *ENISA Threat Landscape*.
- FBI IC3 (2024). *Internet Crime Report*.
- Felt, A. P., et al. (2015). *Improving SSL warnings: Comprehension and adherence*. CHI.
- Kahneman, D. (2011). *Thinking, Fast and Slow*. Farrar, Straus and Giroux.
- Khonji, M., Iraqi, Y., & Jones, A. (2013). *Phishing detection: A literature survey*. IEEE Communications Surveys & Tutorials.
- Mandiant (2023). *M-Trends Report*.
- Microsoft Threat Intelligence (2023). Reporting on AitM phishing and OAuth application abuse.
- MITRE ATT&CK (2025). Enterprise techniques: phishing, valid accounts, and application access token abuse.
- Proofpoint (2024). *State of the Phish*.
- Sunshine, J., et al. (2009). *Crying Wolf: An empirical study of SSL warning effectiveness*. USENIX Security.

License & Disclaimer

Copyright © 2026 Sentyra. The VIGIL concept and its architectural specifications are open-source, licensed under the Apache License 2.0.

Research status. VIGIL is an exploratory research initiative. The models, taxonomies, and frameworks in this paper are intended for research and educational purposes to complement existing security models. This paper does not propose a deterministic security solution, and the concepts should not be deployed in production environments as a primary defensive control without independent validation. For full liability and licensing terms, see LICENSE.md and DISCLAIMER.md in the VIGIL-research repository (github.com/malb8/VIGIL-research).